Thor's Quick Sheets - CC® Domain 3

Contents

Access Control Categories and Types 2

Physical Security Controls 2

Technical or Logical Security Controls 3

Identity and Access Provisioning 3

Administrative Security 4

Thor's Quick Sheets – CC® Domain 3

Access Control Categories and Types

Access Control Categories

- **Administrative (Directive) Controls**: Policies and procedures, regulations, training and awareness.
- **Technical Controls**: Hardware/software/firmware, such as firewalls, routers, encryption.
- **Physical Controls**: Locks, fences, guards, gates, bollards.

Access Control Types

- **Preventative**: Stop actions before they occur (e.g., least privilege, firewalls, IPS).
- **Detective**: Identify actions during or after they occur (e.g., IDS, CCTV, alarms).
- **Corrective**: Fix issues after they occur (e.g., anti-virus, patches).
- **Recovery**: Restore systems after an incident (e.g., backups, DR environments).
- **Deterrent**: Discourage actions (e.g., security guards, lights, warning signs).
- **Compensating**: Alternative controls when primary controls are impractical or costly.

Physical Security Controls

Perimeter Defense:

- **Fences:** Deterrence and prevention; guide entry through controlled points.
- **Gates:** Control points for access; classified by ASTM standards (e.g., residential, commercial).
- **Bollards:** Prevent vehicle entry while allowing foot traffic.
- **Lights:**
  - **Detective and Deterrence;** fully illuminate areas with static or motion-activated lights.
- **CCTV:**
  - **Detective and Deterrence;** monitor perimeter and interior with digital recordings.
- **Locks:**
  - **Key Locks:** Physical keys, susceptible to picking.
  - **Combination Locks:** Low security, vulnerable to brute force.
- **Access Cards:**
  - **Smart Cards:** Contact or contactless, use ICC or RFID.
  - **Magnetic Stripe Cards:** Easy to duplicate.

Mantraps: Two-door rooms, ensure single-person entry.

Turnstiles: Single-person entry to prevent tailgating.

Contraband Checks: Prevent unauthorized items entering or leaving facilities.

Motion Detectors: Alert to unauthorized movement; can use light, ultrasound, or infrared.

Perimeter Alarms: Door/window sensors as part of layered defense.

Walls, Floors, Ceilings: Secure and fire-rated, prevent unauthorized access.

- Exit Security: Doors and windows designed for safe evacuation.

Guards: Deterrent, detective, preventive; must be trained.

Dogs: Used in controlled areas; potential liability for injuries.

Restricted Areas: Visitor badges, logs, and escorts.

  - Vendor Controls: Escort vendors, ensure security checks.

Technical or Logical Security Controls

Access Control Categories:

- **Administrative (Directive) Controls:** Policies, procedures, regulations, training.
- **Logical/Technical Controls:** Firewalls, routers, encryption.
- **Physical Controls:** Locks, fences, guards, gates, bollards.

Access Control Types:

- **Preventative:** Prevent actions (e.g., least privilege, firewalls, IPS, encryption).
- **Detective:** Identify actions during/after occurrence (e.g., IDS, CCTV, alarms).
- **Corrective:** Fix issues post-occurrence (e.g., anti-virus, patches).
- **Recovery:** Restore systems post-incident (e.g., DR environments, backups).
- **Deterrent:** Discourage actions (e.g., security guards, lights, warning signs).
- **Compensating:** Alternative controls when primary solutions are impractical.

Identity and Access Provisioning

Multiple Identities: An entity can have multiple roles with different access levels (e.g., staff, student).
Identity and Access Provisioning Lifecycle: Automate tasks like password changes, account inactivity detection, and access revocation for expired contracts.
Federated Identity:

- **FIDM (Federated Identity Management):** Manages identity across multiple systems with common policies.
  - **SSO:** Allows single sign-on for multiple systems.

Access Control Systems

- **Centralized vs. Decentralized:**
  - **Centralized:** Uniform security posture, easier management, and enhanced security.
    - Cons: Possible traffic overhead and response time issues.
  - **Decentralized:** Faster local response times.
    - Cons: Security inconsistencies and harder management.
  - **Hybrid:** Combines centralized control with local server updates.

Access Control Models:

- **DAC (Discretionary Access Control):**
  - Used for Availability.
  - Access based on object owner's discretion (DACLs).
- **MAC (Mandatory Access Control):**
  - Used for Confidentiality.
  - Access based on labels and clearance.
    - **Labels:** Objects have Labels assigned to them; the subject's clearance must dominate the object's label.
    - **Clearance:** Subjects have Clearance assigned to them.
- **RBAC (Role-Based Access Control):**
  - Used for Integrity.
  - Access based on roles and privileges, facilitates user management.

- **ABAC (Attribute-Based Access Control):** Access based on attributes of subjects, objects, and environment.
- **Context-Based Access Control**: Based on contextual parameters like location and time.
- **Content-Based Access Control:** Based on the attributes or content of an object.

Principles:

- **Least Privilege:** Grant minimum necessary access.
- **Need to Know**: Access only if necessary for task.
- **Separation of Duties:** Divide tasks among multiple individuals to prevent fraud and error.

Administrative Security

Job Rotation:

- Detects errors and fraud by rotating job roles.
- Reduces burnout and increases business understanding.

Mandatory Vacations:

- Prevents continuous task control by one person to detect fraud.
- Accounts are locked and audited during vacations.

NDA (Non-Disclosure Agreement):

- Used with external partners and internal employees.
- Restricts use and sharing of confidential company information.

Background Checks:

- Includes references, degrees, employment, and criminal history.
- Ongoing checks for sensitive positions.

Privilege Monitoring:

- Increased scrutiny for employees with higher access levels.
- Regular audits of access and activities to ensure responsibility.

Top Secret (TS) - Exceptionally grave damage Weapon blueprints, theater or war plans, espionage data.	**Confidential - Exceptionally grave damage** Proprietary information, trade secrets, source code, anything that gives us a competitive advantage.
Secret (S) - Serious damage Troop plans, deployment plans, plans not included in TS plans, reports on shortages or weaknesses.	**Private - Serious damage** PHI, PII, financial data, employee data, payroll.
Confidential (C) - Damage Intelligence reports, operational or battle reports, mobilization plans.	**Sensitive - Damage** Networking diagrams, IP assignments, system and software specific information.
Unclassified (U) Available upon request, does not need a particular classification or has been declassified.	**Public** Websites, advertisements, any information we make publicly available.